İK / Puantaj — Geliştirme Talimatı

Sprint görevi · 19 Ekim 2026 · Personel ekibine iletilecek resmi liste

> Mevcut uygulama iskelet: personel, görev yeri, manuel giriş-çıkış, aylık matris, Excel, dönem kilidi. Aşağıdakiler **bu sprint'te yapılacak**. Belirsiz bırakılan yer yok; aksi yazılıysa sormadan daraltma.

1. Kimlik doğrulama ve roller

İki rol: **admin** ve **personel**.

- Giriş yoksa hiçbir sayfa ve hiçbir API çalışmaz (401).
- Sidebar'daki sahte "Admin" kalkacak; gerçek oturum görünecek.
- API'lerdeki `actorId: "admin"` kalkacak; işlem yapan kullanıcının id'si yazılacak.
- NextAuth env var var, paket/oturum yok — bunu tamamla. Session cookie; her istekte sunucu tarafında rol kontrolü.

admin: personel, görev yeri, şirket, giriş-çıkış, aylık puantaj, dönem kilidi, resmi tatil takvimi, Excel, kullanıcı/rol yönetimi.

personel: sadece **kendi** devam özeti (okuma). Başkasının kaydı, ekleme, silme, düzenleme, dönem kilidi, Excel, tatil tanımı yok. Denemesi 403.

Ekranda butonu gizlemek yetmez; aynı işlem API'den de reddedilecek.

2. API'ler "kapatılmayacak", yetkisiz bırakılmayacak

Kapsam: `/api/employees`, `/api/workplaces`, `/api/attendance/*`, `/api/payroll/lock`, `/api/companies`, `/api/attendance/export`.

- Oturumsuz istek → 401
- personel yazma / başkasının verisi → 403
- Admin GET listeleri de oturumsuz dönmeyecek

API route silme. Arayüz bunları kullanıyor. CORS'u "kapatayım" diye uygulamayı kıracak değişiklik yapma.

3. Resmi tatil takvimi

- Admin, yıl bazlı resmi tatil tanımlar (ekle/sil). Türkiye resmi tatilleri varsayılan yüklenebilsin; admin düzeltebilsin.
- Arefe / yarım gün ayrı işaretlenebilsin.
- Aylık puantajda o günler otomatik resmi tatil; o güne giriş-çıkış yazılamasın (dönem kilitli kuralı gibi).
- Hafta sonu kuralı varsayılan Cmt–Paz olmasın diye görev yeri bazında ayarlanabilsin (6 gün çalışan şantiye).
- Takvim + hafta sonu matriste ve Excel'de aynı görünsün.

4. Mobil / dar ekran

Sadece masaüstü varsayma. Hedef: 375px ve 390px (iPhone), ayrıca 768px.

- Sol sabit 256px menü telefonda kullanılmayacak. Hamburger + overlay drawer; tap dışı / link sonrası kapansın.
- Tablolar (personel, hareket, aylık matris) yatay kayabilsin; içerik kesilmesin.
- Buton/link min. dokunma alanı ~44px.
- Kontrol: Panel, Personel listesi, Günlük giriş-çıkış, Aylık puantaj, giriş ekranı.

5. Puantajın yarım kalan işi

- **Vardiya:** ShiftAssignment şemada var, ekran yok. Admin personel+gün için planlı giriş-çıkış ve mola tanımlayabilsin. Vardiya yokken çalışılan sürenin tamamı fazla mesai sayılmasın (plan 0 iken FM = çalışma bug'ı düzeltilecek).
- **İzin / gün durumu:** Yıllık izin, hastalık, mazeret, yarım gün, resmi tatil, istirahat. Admin günde durum basabilsin (matris hücresi veya günlük ekran). recalculateAttendanceDay izin/tatil durumunu PRESENT/ABSENT ile ezmeyecek.
- **Gün onayı:** isApproved gösteriliyor, hiç onaylanmıyor. Admin günü onaylasın/geri alsın. Paneldeki "onay bekleyen" gerçek sayı olsun. Sahte metinler ("+3 bu ay") kalksın.
- **Personel kaydı:** Listeden silme (yumuşak silme veya pasife çekme; cascade ile tüm puantajın yok olması varsayılan olmasın). Şirket için admin ekranı olsun (şimdi sadece API).

6. Güvenlik / repo

- .env ve .env.local git'e girmeyecek. .gitignore düzelt, örnek .env.example kalsın (şifresiz).
- Audit log: gerçek kullanıcı, eylem, zaman. Admin en azından son işlemleri görebilsin (IP şart değil, kullanıcı şart).
- npm audit 11 açık (6 high, 5 moderate): Tailwind 3 braces/micromatch, Next 15 içindeki eski postcss, exceljs → uuid. **npm audit fix --force yasak** (Tailwind 4 / Next 16 / exceljs düşürme). Gerekirse overrides ile yama; kırıcı major yok.

7. Zaten yapılmış — bozma

> Windows'ta Neon IPv6 yüzünden her sayfa ~5 sn timeout oluyordu. `src/lib/prisma.ts` içinde IPv4-first + pg adapter var. Bunu native Prisma motoruna geri alma. Bağlantı kırmadan ilerle.

8. Kapsam dışı (bu sprint'te yok)

> Bordro (brüt/net, SGK, damga), PDKS/turnike cihaz entegrasyonu, TC/IBAN/maaş alanı, çok kiracılı SaaS.

Kabul kriteri

- Admin ve personel ile ayrı login; personel başkasını ve yazmayı göremez (UI + API denenecek).
- Logout sonrası /api/employees 401.
- Tatil günü matriste tatil, o güne IN/OUT 403/hata.

- 375px'te menü hamburger, puantaj tablosu kaydırılabilir, formlar kullanılabilir.
- İzinli güne giriş basılınca izin silinmez.
- Vardiyasız günde FM şişmez.
- .env commit'te yok.
- Dev server'da IPv6 timeout yok; sayfalar ısınmış halde saniyenin altında açılır.

Maddeler 1–7 ayrı ticket olabilir. Madde 8 "won't do / kapsam dışı" olarak bağlanacak.